

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

一、選擇題

答案	題目
C	1. 近年資通安全事件日益增加，為保障投資人知的權益，依臺灣證券交易所最新修訂的《上市公司重大訊息發布應注意事項參考問答集》必須充分揭露重大資安事件，依照相關要求，請問下列何者「不」是發布重大訊息的必要事件？ (A) 官方網站首頁遭置換為駭客頁面 30 分鐘 (B) 公司 ERP 系統遭勒索軟體加密，導致採購與出貨系統停擺 3 小時 (C) 雲端備份服務供應商故障 8 小時，主線業務系統運作正常，備份資料未遺失亦未外洩 (D) 研發版控制伺服器遭入侵，大量原始碼與未公開技術文件已在暗網販售
B	2. 企業在處理「個人資料保護法」與資安管理系統（ISMS）的整合時，若發生大規模個資外洩事件，下列何種法律責任與應變程序的描述最為準確？ (A) 只要通過 ISO 27001 認證，即可免除個資法下的行政罰鍰與民事賠償責任 (B) 應於知悉事故後，於法定時限內通報中央目的事業主管機關，否則將面臨加重處罰 (C) 個資外洩僅屬於隱私議題，不須納入資通安全事件通報及應變辦法之範疇 (D) 法律規定企業必須對所有個資進行加密，若未加密即視為未盡善良管理人責任
C	3. 隨著「後量子密碼學（PQC）」標準逐漸成形，資安團隊正在更新組織的機敏資料保存規範。考量到攻擊者可能採取「先竊取，後解密（Harvest Now, Decrypt Later）」的威脅模式。針對需要保存 10 年以上的極機密資料，下列何項加密轉型策略最符合當前美國國家標準暨技術研究院（NIST）與業界推薦的「加密敏捷性（Crypto-Agility）」最佳實務？ (A) 將金鑰長度升級至 RSA-4096 或 ECC-521，認定其強度足以抵擋未來 10 年的量子運算威脅 (B) 在 NIST 正式標準完全發布前，暫停所有加密系統更新，避免因採用草案演算法而產生相容性風險 (C) 採用「混合模式（Hybrid Scheme）」，同時結合傳統高強度演算法（如 ECC/RSA）與後量子演算法（如 Kyber/ML-KEM）進行雙重封裝 (D) 全面捨棄公鑰加密體系，改為僅使用對稱式加密（AES-128）進行金鑰交換與資料保存，以規避量子威脅

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

答案	題目
ACD	4. 公司為國內股票上市公司，請問發生下列哪些資訊安全事件須依主管機關規定發布重大訊息？（複選） (A) 公司官方網站遭受服務阻斷攻擊（DDoS） (B) 公司重要資通系統因發現系統重大漏洞，進行維護升級作業須停止服務二日 (C) 公司網路遭到入侵，造成內部文件檔案資料外洩 (D) 公司機密檔案遭駭客以勒索軟體加密
ACD	5. 【題組 1】情境如附圖所示，A 公司因近期接獲金融業之客戶通知，爾後承接其業務時，公司應具備最新版 ISO 27001 資訊安全管理系統之導入並通過第三方驗證。請問 A 公司於導入 ISO 27001 資訊安全管理系統時所申請之驗證範圍，下列哪些項目最為適切？（複選） A 公司所營事業為接受國內公、私領域之各金融業者委託開發與維護金融業使用之「資訊交換系統」，各案之委託金額均達新台幣三千萬至五千萬。 A 公司創立之遠景係成為國內公、私領域金融機構「資訊交換系統」供應商之翹楚。各金融業關注方之需要及期望包含「提供安全、穩定之系統」、「發現資通安全事件應即時通報客戶」。 「資訊交換系統」之部分功能開發作業長期與系統開發商 B 公司合作共同開發，惟系統開發後之原始碼保存於 A 公司自建之資訊機房內，B 公司不保留。所有業務活動之執行作業除電腦作業系統外，均使用自建之應用系統（例如核心資通系統、人力資源管理系統等）或自行開發之軟體，無任何外部之服務（包含雲端服務）使用。 (A) 資訊機房管理業務活動流程 (B) 人力資源管理系統業務活動流程 (C) 系統開發、維護活動 (D) 核心資通系統管理業務活動

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

答案	題目
D	6. 【題組 1】情境如附圖所示，A 公司於執行風險評鑑過程，依據風險評鑑結果選擇適切之資訊安全風險處理選項，並據以產生適用性聲明。請問有關部分之適用性聲明內容，下列何者「有誤」？ A 公司所營事業為接受國內公、私領域之各金融業者委託開發與維護金融業使用之「資訊交換系統」，各案之委託金額均達新台幣三千萬至五千萬。 A 公司創立之遠景係成為國內公、私領域金融機構「資訊交換系統」供應商之翹楚。各金融業關注方之需要及期望包含「提供安全、穩定之系統」、「發現資通安全事件應即時通報客戶」。 「資訊交換系統」之部分功能開發作業長期與系統開發商 B 公司合作共同開發，惟系統開發後之原始碼保存於 A 公司自建之資訊機房內，B 公司不保留。所有業務活動之執行作業除電腦作業系統外，均使用自建之應用系統（例如核心資通系統、人力資源管理系統等）或自行開發之軟體，無任何外部之服務（包含雲端服務）使用。 (A) 5.8 專案管理之資訊安全→適用； 5.19 供應者關係中之資訊安全→適用； 5.20 於供應者協議中闡明資訊安全→適用； 5.22 供應者服務之監視、審查及變更管理→適用 (B) 5.23 使用雲端服務之資訊安全→不適用； 5.24 資訊安全事故管理規劃及準備→適用； 6.6 機密性或保密協議→適用 (C) 6.8 資訊安全事件通報→適用； 8.4 對原始碼之存取→適用； 8.25 安全開發生命週期→適用； 8.27 安全系統架構及工程原則→適用 (D) 8.28 安全程式設計→適用； 8.29 開發及驗收中之安全測試→適用； 8.30 委外開發→不適用

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

答案	題目
A	7. 【題組 1】情境如附圖所示，A 公司接受金融機構之受託業務，客製化開發之各案，其委託金額均達新台幣三千萬至五千萬，依《資通安全管理法》及其子法規定，下列項目何者「有誤」？ A 公司所營事業為接受國內公、私領域之各金融業者委託開發與維護金融業使用之「資訊交換系統」，各案之委託金額均達新台幣三千萬至五千萬。 A 公司創立之遠景係成為國內公、私領域金融機構「資訊交換系統」供應商之翹楚。各金融業關注方之需要及期望包含「提供安全、穩定之系統」、「發現資通安全事件應即時通報客戶」。 「資訊交換系統」之部分功能開發作業長期與系統開發商 B 公司合作共同開發，惟系統開發後之原始碼保存於 A 公司自建之資訊機房內，B 公司不保留。所有業務活動之執行作業除電腦作業系統外，均使用自建之應用系統（例如核心資通系統、人力資源管理系統等）或自行開發之軟體，無任何外部之服務（包含雲端服務）使用。 (A) A 公司提供自行檢測之「資訊交換系統」安全性證明 (B) B 公司提供該「資訊交換系統」之安全性檢測證明 (C) 金融機構客戶自行進行安全性檢測 (D) 金融機構客戶另行委託第三方進行安全性檢測

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

答案	題目
B	8. 【題組 1】情境如附圖所示，A 公司之客戶某金融機構係屬公務機關，其「資訊交換系統」之運作涉及國家機密資訊，故 A 公司執行本「資訊交換系統」開發與維護之相關人員，依《資通安全管理法施行細則》規定「受託業務涉及國家機密者，執行受託業務之相關人員應接受適任性查核，並依國家機密保護法之規定，管制其出境。」，請問有關適任性查核事項內容之說明，下列項目何者錯誤？ A 公司所營事業為接受國內公、私領域之各金融業者委託開發與維護金融業使用之「資訊交換系統」，各案之委託金額均達新台幣三千萬至五千萬。 A 公司創立之遠景係成為國內公、私領域金融機構「資訊交換系統」供應商之翹楚。各金融業關注方之需要及期望包含「提供安全、穩定之系統」、「發現資通安全事件應即時通報客戶」。 「資訊交換系統」之部分功能開發作業長期與系統開發商 B 公司合作共同開發，惟系統開發後之原始碼保存於 A 公司自建之資訊機房內，B 公司不保留。所有業務活動之執行作業除電腦作業系統外，均使用自建之應用系統（例如核心資通系統、人力資源管理系統等）或自行開發之軟體，無任何外部之服務（包含雲端服務）使用。 (A) 曾任公務員，因違反相關安全保密規定受懲戒或記過以上行政懲處 (B) 曾任公務員，因違反相關安全保密規定受懲戒或警告以上行政懲處 (C) 曾犯洩密罪，或於動員戡亂時期終止後，犯內亂罪、外患罪，經判刑確定 (D) 曾犯洩密罪，或於動員戡亂時期終止後，犯內亂罪、外患罪，通緝有案尚未結案
C	9. 請問下列對於生物特徵身份認證（Biometric Authentication）的描述何者較「不」正確？ (A) 指紋辨識的準確度較人臉辨識的準確度高 (B) 視網膜辨識準確率高，然而特徵擷取十分不便是其難以普及的原因 (C) 錯誤拒絕率又稱為型 II（Type II）錯誤，意指原本合法的使用者在身份認證時被拒絕 (D) 臉形辨識常容易因身材及體重的變化而產生誤判，因此會需要定期重新取樣與訓練

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

答案	題目
B	10. 如附圖所示。某企業為強化組織內部資訊安全，導入了多層次防禦機制。請問附圖中的作法最符合下列何種資訊安全之原則？ 1. 外部防火牆過濾不明 IP 連線 2. 員工登入系統需進行多因素驗證 3. 系統內部設定使用者角色與權限控制 4. 資料庫定期備份並加密存放於異地 5. 辦理資安教育訓練，提高人員資安警覺性 (A) 最小權限原則 (Principle of Least Privilege) (B) 縱深防禦原則 (Defense in Depth) (C) 單一防禦原則 (Single Point Defense) (D) 零信任架構 (Zero Trust Architecture)
C	11. 公司執行跨部門專案時發現：部分使用者因臨時專案需要跨部門存取資料。若要兼顧「最小權限原則」與「專案需求」，下列何項是較佳的做法？ (A) 直接給予使用者跨部門權限 (B) 讓使用者共用主管帳號 (C) 建立臨時角色並設定存取期限 (D) 允許使用者自行設定存取權限
ABD	12. 某企業遭遇供應鏈攻擊，駭客利用監控軟體的更新伺服器漏洞入侵內網。為了強化「縱深防禦」體系，防止攻擊者在內網長期潛伏與擴散，下列哪些技術控制措施應納入防禦架構？（複選） (A) 在內部網路實施微切分 (Micro-segmentation)，限制伺服器僅能與其業務相關的節點通訊，阻斷非必要的橫向連線 (B) 移除所有端點與伺服器的本機管理員 (Local Admin) 權限，並導入 LAPS (Local Administrator Password Solution) 管理隨機密碼 (C) 在網路邊界防火牆設定「允許所有出站流量 (Allow Any Outbound)」，以確保業務系統更新不中斷 (D) 部署端點偵測與應變系統 (EDR/XDR)，針對 PowerShell、WMI 等常用的系統管理工具執行異常行為監控

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

答案	題目
B	13. 【題組 2】情境如附圖所示。針對稽核發現(1)「客服人員權限過大」之問題，為了落實職務區隔（SOD）並確保交易安全，下列何種設計模式最符合資安實務？ 「B 金控」為符合國際資安標準，正重新檢視其核心帳務系統的存取架構。該系統目前混合使用地端 Mainframe 與 AWS 雲端微服務。近期稽核發現： (1) 部分客服人員擁有修改客戶信用額度的權限，且未留下核決紀錄 (2) 開發人員為了除錯方便，常態性持有資料庫讀取權限 (3) 系統依賴傳統 VPN 進行遠端維運，一旦連線建立即可存取全網段 (A) 撤銷所有客服人員的系統存取權限，改由客戶自行透過 App 修改額度 (B) 客服人員僅能發起額度調整申請，需由主管系統審核後才生效 (C) 要求客服人員簽署切結書，承諾不隨意修改客戶額度，並每月抽查一次 Log (D) 將所有客服人員帳號設定為「唯讀」，若需修改額度則使用部門共用的主管帳號登入
C	14. 【題組 2】情境如附圖所示。針對審計發現(3)「VPN 連線後可存取全網段」的風險，欲導入零信任網路存取（ZTNA）取代傳統 VPN。在 ZTNA 架構下，決定是否允許連線的核心邏輯為下列何項？ 「B 金控」為符合國際資安標準，正重新檢視其核心帳務系統的存取架構。該系統目前混合使用地端 Mainframe 與 AWS 雲端微服務。近期稽核發現： (1) 部分客服人員擁有修改客戶信用額度的權限，且未留下核決紀錄 (2) 開發人員為了除錯方便，常態性持有資料庫讀取權限 (3) 系統依賴傳統 VPN 進行遠端維運，一旦連線建立即可存取全網段 (A) 僅驗證使用者的帳號密碼，只要憑證正確即建立加密通道 (B) 依據使用者的來源 IP 位址是否在白名單內進行判斷 (C) 基於「身分、裝置健康度、上下文情境（Context）」進行動態授權，且僅建立應用程式層級的連線（App-level tunnel） (D) 使用強效防火牆規則，將 VPN 網段與內部伺服器網段完全隔離

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

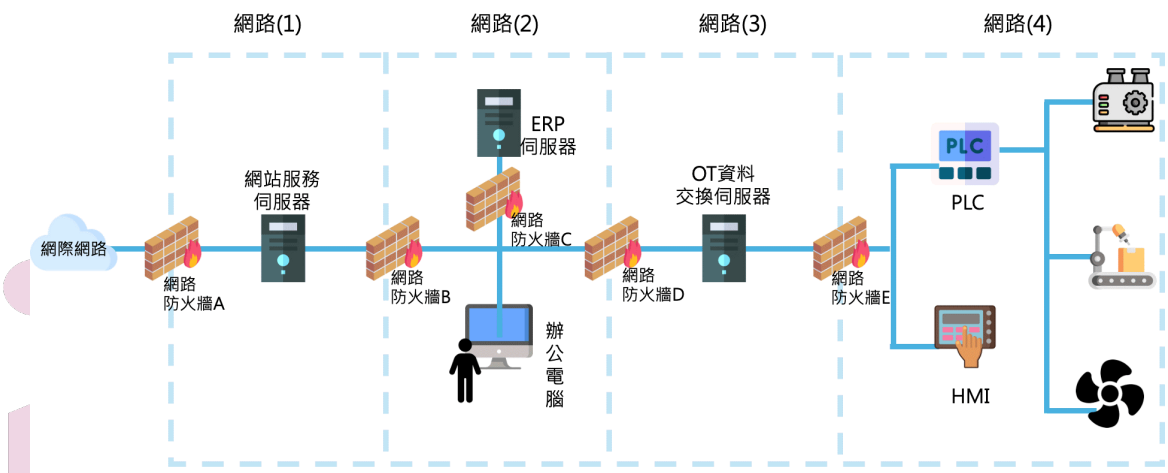
考試日期：115 年 04 月 11 日

答案	題目
B	15. 【題組 2】情境如附圖所示。為了將存取控制從傳統的角色存取控制（RBAC）升級為更靈活的屬性存取控制（ABAC），以解決開發人員權限管理問題。下列何者屬於 ABAC 政策中的「環境屬性（Environment Attribute）」範疇？ 「B 金控」為符合國際資安標準，正重新檢視其核心帳務系統的存取架構。該系統目前混合使用地端 Mainframe 與 AWS 雲端微服務。近期稽核發現： (1) 部分客服人員擁有修改客戶信用額度的權限，且未留下核決紀錄 (2) 開發人員為了除錯方便，常態性持有資料庫讀取權限 (3) 系統依賴傳統 VPN 進行遠端維運，一旦連線建立即可存取全網段 (A) 使用者的職稱與部門代號（如 Level 3 Engineer） (B) 存取請求發生的時間與來源地理位置（如 Office Hour, Taipei IP） (C) 被存取資料的機密等級標籤（如 Confidential） (D) 使用者通過的教育訓練時數紀錄
AD	16. 【題組 2】情境如附圖所示。為了全面強化該金控的資料存取安全，資安團隊計畫導入身分治理與管理（Identity Governance and Administration, IGA）解決方案。下列哪些功能屬於 IGA 的核心範疇，能直接協助解決上述審計發現的權限問題？（複選） 「B 金控」為符合國際資安標準，正重新檢視其核心帳務系統的存取架構。該系統目前混合使用地端 Mainframe 與 AWS 雲端微服務。近期稽核發現： (1) 部分客服人員擁有修改客戶信用額度的權限，且未留下核決紀錄 (2) 開發人員為了除錯方便，常態性持有資料庫讀取權限 (3) 系統依賴傳統 VPN 進行遠端維運，一旦連線建立即可存取全網段 (A) 自動化存取認證（Access Certification/Review）：定期觸發權限盤點流程，要求主管確認員工權限的必要性 (B) 角色挖掘（Role Mining）：分析現有權限分配，確保維持現行角色權限模型不調整 (C) 網頁應用程式防火牆（WAF）：過濾針對 Web 應用層的 SQL Injection 攻擊 (D) 權限生命週期管理（Entitlement Management）：處理人員到職、轉調、離職時的權限自動開通與回收

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

答案	題目
D	17. 下列何項「不」是美國網路安全暨基礎設施安全局（CISA）於 2023 年 4 月發表零信任成熟度模型 2.0 的五個支柱之一？ (A) 網路 (B) 資料 (C) 身份 (D) 稽核
B	18. 附圖為智慧製造企業組織的網路架構圖，請問下列描述何者較「不」正確？  (A) 防火牆 A 至防火牆 E 的部署主要為了強化網路的縱深防禦 (B) 為特別加強防護，屬於 DMZ 網路的網路(2)及網路(4)，應特別加強保護 (C) 為確保網路安全，可考慮採用實體隔離的技術（如 Air Gap）隔離 IT 與 OT 網路 (D) 因網站服務需開放外部連線，因此需要在網路防火牆 A 設定開放網際網路至網站服務伺服器的 HTTPS 協定
B	19. 針對軟體供應鏈攻擊頻傳，組織計畫導入軟體物料清單（SBOM）。在評估現有 DevSecOps 流程時，若要有有效運用 SBOM 來縮短漏洞響應時間，下列何項配套措施必須優先建立？ (A) 要求所有委外廠商必須以紙本形式，隨合約檢附用印後的 SBOM 清單以示負責 (B) 建立漏洞利用交換機制（Vulnerability Exploitability eXchange, VEX），以過濾出雖然存在於組件中但實際不可被利用的漏洞 (C) 禁止開發團隊使用任何版本超過半年的開源函式庫，強制一律更新至最新版 (D) 將 SBOM 資料儲存於離線光碟中，並加密保存於實體保險箱，防止清單外洩

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

答案	題目
BCD	20. 近年來勒索軟體氾濫，造成商譽及財務損失，請問下列哪些可以有效防範與減少損失？（複選） (A) 備份資料只有一份線上（Online）保存 (B) 定期做員工的資安意識訓練及社交工程演練 (C) 定期做網路弱點掃描 (D) 資安合約上可以加上保險項目
A	21. 【題組 3】情境如附圖所示。根據情境中出現的多項異常症狀，若希望有效判斷這些活動是否屬於同一場攻擊行動，下列何種防護設計最能帶來實質效益？ 超好用軟體企業為提升整體資安防護能力，已在使用者端點全面部署 EDR（Endpoint Detection and Response），並於核心網路與重要系統區段導入 NDR（Network Detection and Response）。企業同時建置 XDR（Extended Detection and Response）平台，將來自端點、網路與身分相關的安全事件集中分析。 在營運安排上，企業於上班時段由內部 SOC（Security Operations Center）團隊負責資安監控與事件處置，並在夜間與假日委由外部 MDR（Managed Detection and Response）服務商提供 24x7 的即時監控與回應支援。 某日凌晨，一名員工帳號於非上班時間登入企業環境。隨後，該帳號所使用的裝置開始執行不常見的系統指令，並在短時間內嘗試連線至多個內部系統。 這些行為本身尚未造成服務中斷，但其活動模式橫跨端點行為、帳號使用與內部網路連線，與正常業務行為存在明顯差異。 (A) 結合 EDR、NDR 的事件資料，並由 XDR 進行關聯分析 (B) 以 EDR 為主要來源觀察端點指令與程序行為 (C) 以既有防火牆與網路存取紀錄為判斷依據由 SOC 進行分析 (D) 透過 EDR 收集事件，再由人員進行整體判讀

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

答案	題目
C	22. 【題組 3】情境如附圖所示。事件發生於凌晨，內部 SOC 尚未全面值班。若企業希望兼顧即時應變與人力配置的合理性，依情境設計，下列何種安排最「不」適當？ 超好用軟體企業為提升整體資安防護能力，已在使用者端點全面部署 EDR（Endpoint Detection and Response），並於核心網路與重要系統區段導入 NDR（Network Detection and Response）。企業同時建置 XDR（Extended Detection and Response）平台，將來自端點、網路與身分相關的安全事件集中分析。 在營運安排上，企業於上班時段由內部 SOC（Security Operations Center）團隊負責資安監控與事件處置，並在夜間與假日委由外部 MDR（Managed Detection and Response）服務商提供 24x7 的即時監控與回應支援。 某日凌晨，一名員工帳號於非上班時間登入企業環境。隨後，該帳號所使用的裝置開始執行不常見的系統指令，並在短時間內嘗試連線至多個內部系統。 這些行為本身尚未造成服務中斷，但其活動模式橫跨端點行為、帳號使用與內部網路連線，與正常業務行為存在明顯差異。 (A) 透過自動化工具先行進行風險阻斷 (B) 結合 XDR 的事件可視性，並由 MDR 提供即時分析與回應 (C) 由 SOC 於上班時間統一處理所有事件 (D) 暫時限制所有非上班時間的系統操作

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

答案	題目
A	23. 【題組 3】情境如附圖所示。凌晨，一台置於公司內未關閉的筆電出現異常行為，但尚未觀察到明顯的內部網路連線異動。該裝置持續產生不尋常的程序啟動、記憶體注入行為，並嘗試修改系統設定。若希望快速確認端點是否已遭入侵，並即時降低風險，下列何項設計最「無法」帶來實質效益？ 超好用軟體企業為提升整體資安防護能力，已在使用者端點全面部署 EDR（Endpoint Detection and Response），並於核心網路與重要系統區段導入 NDR（Network Detection and Response）。企業同時建置 XDR（Extended Detection and Response）平台，將來自端點、網路與身分相關的安全事件集中分析。 在營運安排上，企業於上班時段由內部 SOC（Security Operations Center）團隊負責資安監控與事件處置，並在夜間與假日委由外部 MDR（Managed Detection and Response）服務商提供 24x7 的即時監控與回應支援。 某日凌晨，一名員工帳號於非上班時間登入企業環境。隨後，該帳號所使用的裝置開始執行不常見的系統指令，並在短時間內嘗試連線至多個內部系統。 這些行為本身尚未造成服務中斷，但其活動模式橫跨端點行為、帳號使用與內部網路連線，與正常業務行為存在明顯差異。 (A) 透過 NDR 觀察是否存在異常網路通訊 (B) 由 SOC 逐一檢查系統日誌 (C) 將事件送交 XDR 進行跨來源關聯分析 (D) 以 EDR 的端點行為分析與即時回應功能作為主要處置手段

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

答案	題目
ABC	24. 【題組 3】情境如附圖所示。事件發生於夜間，內部 SOC 尚未全面值班，但風險已達需立即處置的程度。在此營運條件下，下列哪些安排最能即時降低風險並兼顧人力配置的合理性？（複選） 超好用軟體企業為提升整體資安防護能力，已在使用者端點全面部署 EDR（Endpoint Detection and Response），並於核心網路與重要系統區段導入 NDR（Network Detection and Response）。企業同時建置 XDR（Extended Detection and Response）平台，將來自端點、網路與身分相關的安全事件集中分析。 在營運安排上，企業於上班時段由內部 SOC（Security Operations Center）團隊負責資安監控與事件處置，並在夜間與假日委由外部 MDR（Managed Detection and Response）服務商提供 24x7 的即時監控與回應支援。 某日凌晨，一名員工帳號於非上班時間登入企業環境。隨後，該帳號所使用的裝置開始執行不常見的系統指令，並在短時間內嘗試連線至多個內部系統。 這些行為本身尚未造成服務中斷，但其活動模式橫跨端點行為、帳號使用與內部網路連線，與正常業務行為存在明顯差異。 (A) 暫時限制所有非上班時間的系統與帳號操作，以降低夜間可能發生的資安風險 (B) 透過 XDR 整合端點、網路與身分事件，並由 MDR 團隊即時介入分析與執行初步回應措施，於隔日交接內部 SOC 進行後續處理 (C) 以 EDR 的端點行為分析與即時回應能力，先行隔離高風險端點，並將處置紀錄保留，待內部 SOC 上班後進行進一步分析 (D) 夜間事件通常風險較低，無須即時處理
D	25. 依據數位發展部資通安全署發布之新版「公務機關 IT 資安治理成熟度評估參考指引」，請問該指引所定成熟度評估模型的成熟度類級共有幾項？ (A) 3 (B) 4 (C) 5 (D) 6

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

答案	題目
C	26. 關於執行風險分析時應考慮的因素，下列何者較「不」適切？ (A) 事件與後果之可能性須納入考量 (B) 風險因子的複雜性與連結性須納入考量 (C) 時間相關因素與波動性不是考慮的因素 (D) 現有控制措施的有效性須納入考量
B	27. 面對日益嚴峻的軟體供應鏈攻擊（如 Log4j 事件），企業欲建立快速識別受駭資產的能力。下列何項機制能最有效地協助組織在漏洞揭露當下，精準定位內部系統是否使用了含有漏洞的第三方元件？ (A) 定期執行外部弱點掃描（Vulnerability Scanning） (B) 建立並維護軟體物料清單（SBOM） (C) 要求供應商提供每季一次的滲透測試報告 (D) 在所有伺服器上安裝主機型入侵偵測系統（HIDS）
BCD	28. 企業正準備更新 ISO 27001 資訊安全管理系統（ISMS）至 2022 年版。在進行風險評估與處置計畫時，針對新增的控制措施「威脅情資」，下列哪些是實務上應包含的關鍵作業流程？（複選） (A) 僅收集內部防火牆日誌，不需參考外部資訊 (B) 訂閱並分析來自資安資訊分享與分析中心（ISAC）或廠商的情資 (C) 將情資與內部環境進行關聯分析，判斷相關性與衝擊 (D) 依據情資調整防禦策略（如更新 WAF 規則或封鎖惡意 IP）
B	29. 【題組 4】情境如附圖所示。此案例顯示傳統的「人臉辨識」已難以應對 AI 威脅。從風險評估的角度，下列何種「流程面」的控制措施是防範商務電子郵件詐騙與 Deepfake 詐騙的最後一道防線？ 一家跨國製造業的財務長接到一通來自「集團執行長」的視訊電話，要求立即匯款一筆巨額資金至海外帳戶以進行秘密併購。視訊中執行長的影像與聲音均無異狀。然而，這實際上是攻擊者利用 AI Deepfake 技術生成的詐騙。所幸財務長在最後一刻依循公司規定的「例外匯款雙重確認流程」，透過內部加密通訊軟體向執行長文字確認，才揭穿騙局。 (A) 部署垃圾郵件過濾閘道器（Email Security Gateway） (B) 實施外部驗證（Out-of-Band Verification），透過第二種不同管道確認指示 (C) 要求所有高階主管定期更換視訊會議軟體的密碼 (D) 提升視訊會議軟體的解析度，以便看清對方臉部細節

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

答案	題目
B	30. 【題組 4】情境如附圖所示。若要從「技術面」增強身分驗證的強度，降低帳號被盜用發起詐騙的風險，下列何種機制最「不」具身分驗證有效性？ 一家跨國製造業的財務長接到一通來自「集團執行長」的視訊電話，要求立即匯款一筆巨額資金至海外帳戶以進行秘密併購。視訊中執行長的影像與聲音均無異狀。然而，這實際上是攻擊者利用 AI Deepfake 技術生成的詐騙。所幸財務長在最後一刻依循公司規定的「例外匯款雙重確認流程」，透過內部加密通訊軟體向執行長文字確認，才揭穿騙局。 (A) 簡訊傳送一次性密碼 (SMS OTP) (B) 使用信任來源白名單機制 (C) 電子郵件發送驗證連結 (D) 基於 FIDO2/WebAuthn 標準的實體金鑰或 Passkey
C	31. 【題組 4】情境如附圖所示。針對此類利用 AI 技術的新興威脅，資安團隊在進行年度風險評鑑時，應如何調整其風險機率 (Likelihood) 的評估準則較為適切？ 一家跨國製造業的財務長接到一通來自「集團執行長」的視訊電話，要求立即匯款一筆巨額資金至海外帳戶以進行秘密併購。視訊中執行長的影像與聲音均無異狀。然而，這實際上是攻擊者利用 AI Deepfake 技術生成的詐騙。所幸財務長在最後一刻依循公司規定的「例外匯款雙重確認流程」，透過內部加密通訊軟體向執行長文字確認，才揭穿騙局。 (A) 因 AI 技術門檻高，應調降此類攻擊發生的機率 (B) 維持既有評估，認為 Deepfake 僅會發生在國家級攻擊 (C) 應調升機率，因 GenAI 工具普及降低了攻擊成本與技術門檻 (D) 無法評估，將其列為不可抗力的例外風險

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

答案	題目
ABC	32. 【題組 4】情境如附圖所示。為了建立具備「深度防禦」的詐騙防護體系，下列哪些措施應納入整體的資安策略中？（複選） 一家跨國製造業的財務長接到一通來自「集團執行長」的視訊電話，要求立即匯款一筆巨額資金至海外帳戶以進行秘密併購。視訊中執行長的影像與聲音均無異狀。然而，這實際上是攻擊者利用 AI Deepfake 技術生成的詐騙。所幸財務長在最後一刻依循公司規定的「例外匯款雙重確認流程」，透過內部加密通訊軟體向執行長文字確認，才揭穿騙局。 (A) 定期舉辦社交工程演練，並將 Deepfake/AI 語音納入演練情境 (B) 建立嚴格的財務放行流程，高額款項必須由兩人以上簽核（Dual Control） (C) 採購能偵測 Deepfake 訊號（如眨眼頻率異常、語音合成痕跡）的監控方案 (D) 禁止公司內部使用任何視訊會議軟體，改回實體會議
B	33. 有關風險處理的描述，下列何者最為適切？ (A) 風險處理的理由只需考量經濟可做到的結果，其它影響到組織的利害相關者觀點不需納入考量 (B) 持續監督與審查風險處理實施的過程，以確保風險處理能夠有效完成 (C) 風險處理方式選定後，即不可任意調整，須持續進行完成該風險處理以達成結果 (D) 只要精心設計與實施風險處理，一定會產生預期的結果，不會有預期不到的後果
B	34. 電力的可用性是資訊系統營運之重要環節，針對供電風險，下列何者較「不」適切？ (A) 建置備援發電機組 (B) 透過資安保險避免電力短缺問題 (C) 選擇供電穩定之地理區域 (D) 規劃遠端備援中心亦須評估供電可靠度
A	35. 企業在導入生成式 AI 進行輔助程式開發時，評估其存在原始碼外洩與惡意程式碼注入的風險。在不完全禁止使用的前提下，下列何項風險降低（Risk Mitigation）策略最能兼顧安全性？ (A) 僅允許使用企業地端部署或私有雲版本的 LLM 模型，並實施資料不落地政策 (B) 要求開發人員簽署保密協定（NDA），將風險完全轉移給員工個人承擔 (C) 部署資料外洩防護（DLP）系統過濾所有連外流量，阻擋所有含程式碼特徵的封包 (D) 僅依靠公有雲 AI 服務供應商的預設隱私條款，視為風險已接受

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

答案	題目
BC	36. 在 OWASPLLM Top10 中，針對 AI 運算中的風險，以下哪些項目的描述有誤？（複選） (A) 對高風險操作加入人工審核，可降低提示詞注入漏洞（Prompt Injection）的衝擊 (B) 間接提示詞注入（Indirect Prompt Injections）不包含供應鏈之外部來源 (C) 應用程式提供所有使用者相同的 API token 可限制其權限 (D) 應定期執行滲透測試與紅隊演練，並將 LLM 視為不受信任實體
A	37. 【題組 5】情境如附圖所示。依據 IEC 62443 標準與普渡模型（Purdue Model）概念，為了防止 IT 威脅擴散至 OT，下列何種網路架構設計最為關鍵且有效？ 某半導體設備製造商為提升良率，將工廠營運技術（OT）網路與企業資訊（IT）網路進行介接，以便即時分析機台數據。某日，IT 網段的一台人資電腦感染了具備橫向移動能力的勒索病毒，資安團隊擔心病毒會擴散至 OT 網段影響產線運作。 (A) 在 IT 與 OT 之間建立工業控制系統 DMZ（IDMZ），並終止直接連線 (B) 將 IT 與 OT 網路完全透過實體氣隙（Air Gap）斷開，禁止任何資料交換 (C) 允許 OT 設備直接連線至網際網路進行修補更新，以保持系統最新 (D) 在所有 OT 設備上安裝與 IT 相同版本的商用防毒軟體
A	38. 【題組 5】情境如附圖所示。若不幸發生資安事件波及 OT 環境，在進行事件應變（Incident Response）時，OT 環境與 IT 環境最大的優先順序差異為何？ 某半導體設備製造商為提升良率，將工廠營運技術（OT）網路與企業資訊（IT）網路進行介接，以便即時分析機台數據。某日，IT 網段的一台人資電腦感染了具備橫向移動能力的勒索病毒，資安團隊擔心病毒會擴散至 OT 網段影響產線運作。 (A) IT 優先考量機密性；OT 優先考量人員安全與可用性 (B) IT 優先考量可用性；OT 優先考量資料完整性 (C) 兩者皆以保護智慧財產權為第一優先 (D) OT 環境應優先立即斷電，以保存數位證據

115 年第一次資訊安全工程師-中級能力鑑定【公告試題】

第一科：資訊安全規劃實務

考試日期：115 年 04 月 11 日

答案	題目
B	39. 【題組 5】情境如附圖所示。針對 OT 場域中難以安裝修補程式及防護軟體的老舊控制器（PLC），資安工程師計畫採用「虛擬修補（Virtual Patching）」技術。請問此技術通常是透過下列何種設備實現？ 某半導體設備製造商為提升良率，將工廠營運技術（OT）網路與企業資訊（IT）網路進行介接，以便即時分析機台數據。某日，IT 網段的一台人資電腦感染了具備橫向移動能力的勒索病毒，資安團隊擔心病毒會擴散至 OT 網段影響產線運作。 (A) 端點防毒軟體（Antivirus） (B) 工控入侵防禦系統（OT IPS/Firewall） (C) 網頁應用程式防火牆（WAF） (D) 郵件安全閘道器（Email Gateway）
ABC	40. 【題組 5】情境如附圖所示。延續上一題，為了提升 OT 環境的可視性（Visibility）與異常偵測能力，同時避免影響產線運作，下列哪些部署方式是推薦的實務作法？（複選） 某半導體設備製造商為提升良率，將工廠營運技術（OT）網路與企業資訊（IT）網路進行介接，以便即時分析機台數據。某日，IT 網段的一台人資電腦感染了具備橫向移動能力的勒索病毒，資安團隊擔心病毒會擴散至 OT 網段影響產線運作。 (A) 使用交換器的 Port Mirroring（SPAN）功能，將流量複製給偵測設備進行被動分析 (B) 在 PLC 控制網路上進行主動式低頻率漏洞掃描（Active Scanning） (C) 部署網路分流器（Network TAP）擷取實體線路訊號 (D) 在 SCADA 主機上安裝輕量級的代理程式，收集日誌與效能數據

《以下空白》